

klixbd.com

Software Requirements Specification

Development Scope — v1.0

Field	Value
Version	v1.0
Date	April 24, 2026
Stack	Laravel 11 · MySQL 8 · Redis 7 · React 18 · Tailwind 3 · Pusher Channels
Scope	Single-vendor D2C ecommerce, Bangladesh (nationwide), EN + BN
Acquisition	Meta (FB/IG) paid ads — quick-checkout optimized
Payments	COD, bKash, Nagad, Rocket, SSLCOMMERZ
Couriers	Pathao, Steadfast, RedX, Sundarban

1. Introduction

1.1 Purpose

Defines functional and non-functional requirements for klixbd.com. Limited to what is needed for engineering, DevOps, and QA to design, build, test, and deliver v1.0.

1.2 Scope (in / out)

In scope

- Storefront (EN/BN)
- Quick checkout + payments (COD, bKash, Nagad, SSLCOMMERZ)
- Orders, inventory, variants
- Shipping rules + multi-courier integration
- Call center / confirmation module
- Marketing tools (coupons, flash sales, loyalty, referrals, landing pages, abandoned cart)
- Admin panel with RBAC
- Reports (sales, inventory, profit, ads)
- Realtime via Pusher
- Tracking: GTM (web + server), Meta Pixel + CAPI, GA4, TikTok Pixel
- Fraud/fake-order screening (FraudBD / FraudChecker)

Out of scope (v1.0)

- Native mobile apps
- Multi-vendor marketplace
- B2B wholesale
- Subscriptions
- International shipping

1.3 Conventions

- Requirement IDs: REQ-<MODULE>-<NUM>; NFRs: NFR-<CAT>-<NUM>.
- Priority: MUST (v1.0), SHOULD (v1.x), NICE (v2+).
- Money stored as BDT paisa (integer); UI format ₳1,234.
- Dates stored UTC; displayed Asia/Dhaka.
- Phones stored E.164 (+8801XXXXXXXX).

2. Users & Roles

Role	Scope
Super Admin	All modules + integrations + roles + settings.
Store Manager	All modules except integrations, roles, tax settings.

Role	Scope
Operations (Dispatch)	Orders, shipping, courier booking, labels, reconciliation.
Inventory Manager	Catalog, variants, stock, PO, costs.
Marketing	Coupons, flash sales, campaigns, landing pages, reviews moderation.
Call Agent	Assigned call tasks only; set dispositions; notes.
Call Supervisor	All call tasks; reassignment; KPIs; recordings.
Accountant	Finance reports, PO, remittance, refunds ($\leq$ threshold).
Content Editor	CMS, blog, landing pages, SEO metadata; no pricing/stock edits.
Read-only Analyst	Read-only access to reports.
Customer	Storefront: browse, cart, checkout, account, orders, wishlist, reviews.

3. Architecture

3.1 Style

- Modular monolith (Laravel 11).
- React 18 SPAs for storefront and /admin — Inertia.js or Vite bundle.
- Queues on Redis (Horizon). Scheduled tasks via Laravel Scheduler.
- Event-driven integrations (CAPI, SMS, courier) via Laravel Events + retryable Jobs.

3.2 Components

Component	Technology / Purpose
Web tier	Nginx + PHP-FPM 8.3; Laravel Octane (Swoole) optional for hot endpoints.
API + SPA	Laravel 11 backend; React 18 + Tailwind 3 frontends; TypeScript strict.
DB	MySQL 8 (RDS Multi-AZ), utf8mb4, JSON columns, FULLTEXT search.
Cache/Queue/Lock	Redis 7 (ElastiCache) — cache, sessions, Horizon queues, stock locks.
Realtime	Pusher Channels — public, private, presence.
Storage	S3 + CloudFront (images, invoices, exports). AVIF/WebP + JPEG fallback.
Email / SMS	SES or SendGrid; SSL Wireless or Alpha SMS (masked sender "KLIXBD").
Observability	Sentry (errors), CloudWatch (logs/metrics), Telescope (staging), UptimeRobot.
Auth	Laravel session + Sanctum tokens; 2FA (TOTP) mandatory for admin.
Search	MySQL FULLTEXT at launch; migrate to Meilisearch when SKUs > 5k.

3.3 Domains (app/Domain/*)

- Catalog
- Inventory
- Pricing
- Checkout
- Order
- Fulfillment
- CRM
- Marketing
- Platform

3.4 Environments

Env	Domain	Data	Purpose
Local	klixbd.test	Seed fixtures	Dev workstations.
Dev/CI	dev.klixbd.internal	Anonymized sample	CI builds, branch previews.
Staging	stage.klixbd.com	Prod clone (masked)	QA, UAT, load/pentest.
Prod	klixbd.com / admin.klixbd.com	Live	SLA-bound production.

4. Storefront

4.1 Pages & Components

Page	Key Requirements
Home	Admin-editable banners (schedule on/off), featured categories, best-sellers, flash-sale strip, testimonials. LCP ≤ 2.5s mobile.
PLP (category/search)	SSR first page; filters (price, brand, category, size, color, rating, in-stock, discount band); sort (relevance, price, newest, bestseller, rating); pagination or infinite scroll.
PDP	Gallery + zoom + video; variant selector (up to 3 axes) with disabled unavailable combos; live stock per variant; Buy Now (opens Quick Checkout) + Add to Cart; reviews block; JSON-LD Product schema; related + bundles.
Search	200ms debounced overlay; FULLTEXT; analytics (search_queries table) for zero-result tuning.

Page	Key Requirements
Cart	Drawer + /cart route; qty adjust; coupon input with live validation; shipping estimator. Stock NOT reserved on add.
Account	Orders history, track, reorder, returns; addresses (≤ 10); wishlist (local $\rightarrow$ sync on login); loyalty points; referral code.
Content	Blog, policy pages, landing pages. Scheduled publish. Per-page SEO.

4.2 Key Requirements

- REQ-SF-001 (MUST) — Persistent cart via signed cart_token cookie; merge on login.
- REQ-SF-002 (MUST) — Bangla/English toggle persists via "locale" cookie; product translations in product_translations.
- REQ-SF-003 (MUST) — JSON-LD (Product, BreadcrumbList, Review aggregate) on relevant pages.
- REQ-SF-004 (MUST) — sitemap.xml nightly; robots.txt configurable (blocks all on staging).
- REQ-SF-005 (MUST) — Pixel + CAPI events fired for PageView, ViewContent, Search, AddToCart, InitiateCheckout (see Section 13).
- REQ-SF-006 (SHOULD) — Live stock indicator via Pusher (public.stock.{variant_id}) when stock < 10.
- REQ-SF-007 (MUST) — Wishlist stored server-side after login; anonymous in localStorage.
- REQ-SF-008 (MUST) — Reviews: star distribution, photo upload (≤ 3), verified-purchase badge; submission gated to delivered orders.

5. Checkout & Payments

5.1 Quick Checkout (single page, COD default)

- Fields: Name, Phone (req.), optional Email, Division, District, Thana, Address, Qty.
- Delivery option auto-selected by zone with visible fee.
- Payment tiles: COD (default), bKash, Nagad, SSLCOMMERZ.
- Expandable coupon; order summary; "Place Order" CTA.
- Goal: ≤ 3 taps and ≤ 4 fields from PDP to confirmation.

5.2 Requirements

- REQ-CHK-001 (MUST) — checkout_sessions row created on entry (uuid, cart snapshot, pricing snapshot, TTL 60 min, idempotency_key).
- REQ-CHK-002 (MUST) — Price freeze: snapshot locked; catalog changes do not affect in-flight sessions.
- REQ-CHK-003 (MUST) — Stock reserved at order create (Redis lock on variant_id); released on Cancelled before Dispatched.
- REQ-CHK-004 (MUST) — OTP policy admin-configurable: off / COD only / all / above threshold. 6-digit, TTL 5 min, 3 attempts, rate limits (phone 5/h, IP 10/h). Cache verified numbers 7 days.
- REQ-CHK-005 (MUST) — Fraud: call FraudBD/FraudChecker on submit; score 0–100 + rto_count + last_courier. Rules: score $\geq 80 \rightarrow$ reject; 50–79 $\rightarrow$ Pending Review; < 50 $\rightarrow$ allow.

- REQ-CHK-006 (MUST) — Blacklist: phone, IP, email, device fingerprint. Writes propagate < 30s.
- REQ-CHK-007 (MUST) — High-risk: require partial-advance (configurable %, default 20%) via bKash/Nagad before confirm.
- REQ-CHK-008 (MUST) — Idempotency-Key header supported on place-order; replays return stored response.
- REQ-CHK-009 (MUST) — PSP failure → user-friendly error + session resumable; fallback to COD or SSLCOMMERZ without losing form state.
- REQ-CHK-010 (MUST) — Capture fbp, fbc, utm_*, fbclid, gclid, landing_page_id, referrer on session + persist on order.
- REQ-CHK-011 (MUST) — Abandoned: sessions with phone/email captured, not completed after 15 min → abandoned_carts row. Recovery: SMS + Messenger (30m), email (6h), retarget event (24h). Recovery link pre-fills checkout.

5.3 Payment Drivers

Method	Priority	Pattern	Notes
COD	MUST	Internal state machine	Default. Remittance tracked vs courier invoice.
bKash (Tokenized)	MUST	Grant → create → execute → query	Direct merchant. Poll verify after execute.
Nagad Merchant PGW	MUST	Hosted redirect (signed)	Verify via check-status API.
SSLCOMMERZ	MUST	Hosted redirect v4	Cards + MFS + net banking fallback.
AamarPay	SHOULD	Hosted redirect	Aggregator redundancy.
Rocket	SHOULD	Via SSLCOMMERZ	Covered by aggregator.

All drivers implement PaymentDriverContract: initiate(session), verify(ref), refund(paymentId, amount), webhook(payload).

6. Orders

6.1 State Machine

State	Transitions To	Trigger / Actor
New	Pending Review, Confirmed, Cancelled	System on order create.
Pending Review	Confirmed, Cancelled, Hold	Fraud rule match.
Hold	Confirmed, Cancelled	Awaiting partial advance or clarification.

State	Transitions To	Trigger / Actor
Confirmed	Packed, Cancelled	Agent / OTP verified.
Packed	Dispatched, Cancelled	Ops.
Dispatched	In Transit, Returning, Cancelled	Courier API.
In Transit → Out for Delivery → Delivered	(next)	Courier webhook.
Returning → Returned	(next)	Courier webhook.
Return Requested → Return In Transit → Returned	(next)	Customer post-delivery.
Cancelled / Closed	terminal	

6.2 Requirements

- REQ-ORD-001 (MUST) — Order creation atomic: insert order + items, decrement stock, write stock_movements, write order_timeline — all inside DB tx + Redis lock on variant_id.
- REQ-ORD-002 (MUST) — Order code: KLX-YYMM-XXXXX (sequence-generated, unique).
- REQ-ORD-003 (MUST) — Events on create: OrderCreated → SendCapiPurchase, SendOrderSms, NotifyOpsPusher, AssignCallTask, GenerateInvoicePdf.
- REQ-ORD-004 (MUST) — Admin order list: server-side pagination, filters (status, date, courier, payment, city, campaign, agent, risk band, amount, product, phone). Saved views per user.
- REQ-ORD-005 (MUST) — Bulk actions: assign agent, dispatch, print labels, cancel, export CSV.
- REQ-ORD-006 (MUST) — Returns: customer-initiated flow → RMA code → admin approve → reverse pickup → receive → optional restock → refund.
- REQ-ORD-007 (MUST) — Refund via original source where possible; COD → bKash/Nagad to customer-supplied number; ≥ ₹10,000 requires dual approval.
- REQ-ORD-008 (MUST) — Per-order timeline with actor + diff for every transition.
- REQ-ORD-009 (MUST) — PDF invoice on confirm (brand + BIN + items + VAT line + totals); 80mm thermal label + A5 packing slip printable.

7. Catalog, Inventory & Variants

7.1 Product Model

Field	Notes
slug, name, short_desc, description	Translations in product_translations (locale keyed).
brand_id, category_id, tags[]	Hierarchy up to 3 levels; one brand (optional).
has_variants	If true, price/stock live on variants.
base_price_paisa, compare_price_paisa, cost_price_paisa	MRP strike-through + COGS.
weight_g, length/width/height_cm	Courier rate + packing.
tax_class_id, shipping_class_id, handling_days, published_at	Tax, shipping rule, lead time, schedule.
status	draft / active / archived.
seo (title, description, noindex)	Per-product override.
custom_fields JSON	Arbitrary structured data.

7.2 Variants & Options

- REQ-VAR-001 (MUST) — Up to 3 option axes (Size, Color, Material). Variants = Cartesian; disable per combo.
- REQ-VAR-002 (MUST) — Per variant: SKU, barcode, price override, cost_price, weight, image, status, stock_qty, backorder.
- REQ-VAR-003 (MUST) — Variant picker updates image + price + stock + SKU without reload.
- REQ-VAR-004 (MUST) — Bulk variant price matrix editor.

7.3 Inventory

- REQ-INV-001 (MUST) — Single default warehouse at launch; schema supports multi-warehouse.
- REQ-INV-002 (MUST) — stock_movements is source of truth (qty_delta, reason, reference). variants.stock_qty is derived.
- REQ-INV-003 (MUST) — Low-stock threshold per variant → Pusher event + Ops task.

- REQ-INV-004 (MUST) — Backorder flag → accept orders at zero stock with "dispatch in N days" note.
- REQ-INV-005 (MUST) — Reservation: decrement on create; reverse on Cancelled (pre-dispatch); restore on physical receipt for returns.
- REQ-INV-006 (MUST) — Purchase Orders: Draft → Sent → Receiving → Received → Closed. Partial receive updates cost via moving average (default) or FIFO (config).
- REQ-INV-007 (MUST) — CSV import/export for products + variants with preview + validation.
- REQ-INV-008 (MUST) — Media library: S3 presigned upload; auto-resize (200/800/1600) + AVIF/WebP; alt + title per asset.

8. Shipping & Courier

8.1 Zones & Rates

- REQ-SHP-001 (MUST) — Admin-defined zones (default Inside Dhaka / Outside Dhaka / Sub-Urban).
- REQ-SHP-002 (MUST) — Per-zone: base rate, per-kg surcharge, free-shipping threshold, optional express rate.
- REQ-SHP-003 (MUST) — Shipping class per product overrides zone defaults.
- REQ-SHP-004 (MUST) — Rules: flat, weight-based, tiered price-based.
- REQ-SHP-005 (SHOULD) — Live courier rate lookup when supported; fallback to internal table.

8.2 Courier Driver Contract

Every courier implements CourierContract with uniform methods:

Method		Purpose		
rateQuote(order)		Return rate list + ETA.		
createParcel(order)		Book; return consignment_id, tracking_url, label_url.		
cancelParcel(consignment_id)		Pre-pickup cancel.		
getStatus(consignment_id)		Poll status when webhooks lag.		
handleWebhook(payload)		Verify signature, map to internal status, update timeline, emit Pusher.		
getPayoutReport(from, to)		COD remittance for reconciliation.		
Courier	Launch	Create	Webhook	Notes
Pathao	MUST	Yes	Yes	Best API; full rate lookup.
Steadfast	MUST	Yes	Yes	Rate table in-app.
RedX	MUST	Yes	Yes	Strong Dhaka SLA.
Sundarban	SHOULD	Yes	Partial	Outside-Dhaka + rural.

Method		Purpose		
	v1.1			
Manual	MUST	N/A	Manual	Self-ship / VIP.

8.3 Dispatch

- REQ-DSP-001 (MUST) — Ops selects order(s) → Dispatch → choose courier (or auto-rule) → createParcel → persist consignment + label → print bundle.
- REQ-DSP-002 (MUST) — Auto-routing rules editable (e.g., Inside Dhaka → Pathao; Outside + ≤2kg → Steadfast; Rural → Sundarban).
- REQ-DSP-003 (MUST) — Retry failed bookings with exponential backoff (3×); after max → manual flag.
- REQ-DSP-004 (MUST) — Daily pickup manifest PDF per courier.
- REQ-DSP-005 (MUST) — SMS customer on dispatch with tracking URL.
- REQ-DSP-006 (MUST) — Webhook idempotency via event_id; map to internal states; fire OrderDelivered / OrderReturned events.
- REQ-DSP-007 (MUST) — Reconcile job every 30 min: poll getStatus for orders whose status is Dispatched/InTransit and last update > 6h.
- REQ-DSP-008 (MUST) — COD remittance — upload/fetch courier sheet; match to consignments; surface variances; accountant resolves.

9. Call Center / Order Confirmation

9.1 Agent Dashboard

- REQ-CC-001 (MUST) — "My Queue" — orders assigned to agent, sorted by age, with status chips.
- REQ-CC-002 (MUST) — Call action reveals masked phone; optional SIP/WebRTC integration.
- REQ-CC-003 (MUST) — Call screen shows order summary + fraud_score + customer history + address.
- REQ-CC-004 (MUST) — Disposition required to leave queue.

9.2 Dispositions

Code	Next State	Use
Confirmed	Confirmed	Proceed to packing.
Confirmed — Address Updated	Confirmed	Customer corrected address/phone.
Callback Requested	—	Reschedule.
Partial Advance Requested	Hold	Awaiting advance payment link.
Item Changed / Added	Confirmed	Agent edits order with audit.
No Answer	—	Auto-retry 2h / 1d; N fails → Cancel.

Code	Next State	Use
Wrong Number	Pending Review	Trigger SMS + supervisor review.
Not Interested	Cancelled	Capture reason.
Duplicate / Fake	Cancelled	Blacklist phone; boost fraud.
Out-of-Service Area	Cancelled	Refund any advance.

9.3 Assignment & Supervisor

- REQ-CC-010 (MUST) — Round-robin auto-assign to online agents with capacity caps (configurable).
- REQ-CC-011 (MUST) — Rule-based routing (high-value → senior; Bangla-pref → Bangla agents).
- REQ-CC-012 (MUST) — Presence via presence-agents.call-center channel.
- REQ-CC-013 (MUST) — Supervisor wallboard (live queue, longest wait, per-agent occupancy, RTO today).
- REQ-CC-014 (SHOULD) — Call recording URL attached to order (consent required).

10. Marketing Modules

10.1 Coupons

- code, type (percent/fixed/free_shipping), value, min_subtotal, starts_at, expires_at, usage_limit_total + per_customer, eligible/excluded products + categories, stacking flag.
- Auto-apply rules (first-time, cart value, specific products).
- Bulk single-use code generator, exportable CSV.
- Atomic validator returns structured error codes.

10.2 Flash Sales

- Scheduled window + applicable variants + override price + max units.
- Live countdown + Pusher-driven units-remaining on PDP/PLP/home.
- Atomic unit-limit enforcement (no oversell).

10.3 Bundles

- Fixed bundles (own PDP, bundled price).
- Dynamic "Buy X get Y at Z%" rules (PDP + cart upsell).
- Free-gift-with-purchase (auto-add non-priced item).

10.4 Loyalty & Referrals

- Points ledger per customer; earn rate + redemption rate configurable.
- Earn triggers: delivered order, review, referral conversion, birthday.
- Expiry default 12 months (configurable).
- Redeem at checkout with cap rule.
- Tier system (Silver/Gold/Platinum) with benefits.

- Referral code + URL; referrer gets points on invitee first delivered order; invitee gets coupon.
- Abuse protection: device fp, phone match, first-order-only.

10.5 Landing Page Builder

- REQ-LPB-001 (MUST) — Drag-drop editor; sections: hero, features, price, reviews, FAQ, video, timer, inline order form.
- REQ-LPB-002 (MUST) — Per-page slug (/l/<slug>), SEO, optional Pixel ID override.
- REQ-LPB-003 (MUST) — Inline minimal order form (Name, Phone, Address, Qty) → checkout API.
- REQ-LPB-004 (MUST) — A/B test split with lift report.
- REQ-LPB-005 (MUST) — Capture UTM/fbclid; persist on session + order.
- REQ-LPB-006 (SHOULD) — Version history + rollback.

10.6 Abandoned Cart

- Trigger: checkout_session with phone/email captured, not completed after 15 min.
- Flow (admin-editable): SMS + Messenger (30m), email (6h), retarget custom event (24h).
- Recovery link pre-fills checkout + applies optional coupon.
- Funnel report: abandoned → contacted → reopened → purchased.

10.7 Reviews

- Gated to delivered purchasers; moderated approve/reject.
- 1–5 stars + title + body + ≤3 photos + optional video.
- Post-delivery review request (SMS + email) 3 days after delivery; points on submit.
- Brand reply; JSON-LD aggregate ratings on PDP.

10.8 Email / SMS Campaigns

- Segment builder (RFM, last order, city, tag).
- Template library; A/B subject; UTM auto-append.
- Throttling: opt-out + per-customer daily cap.
- Automations: welcome, win-back, review request, birthday.

10.9 Attribution

- Capture first-touch + last-touch: utm_source/medium/campaign/content/term, fbclid, gclid, ttclid, referrer, landing_url.
- Campaign report: revenue + orders + AOV + ROAS by utm_campaign + landing_page_id.
- SHOULD: nightly Meta Marketing API pull for ad spend.

11. Admin Panel

- REQ-ADM-001 (MUST) — SPA at /admin; role-aware nav; policy guards per route.
- REQ-ADM-002 (MUST) — User invite via email; force password reset first login; mandatory 2FA TOTP.
- REQ-ADM-003 (MUST) — Activity/audit log per write (user, ip, ua, before/after diff).

- REQ-ADM-004 (MUST) — Settings: general, payments, shipping zones, tax, templates (SMS/email), integrations (keys), legal.
- REQ-ADM-005 (MUST) — Global search (orders, customers, products) with fuzzy match.
- REQ-ADM-006 (MUST) — Feature flag panel (Laravel Pennant) — per env or % rollout.
- REQ-ADM-007 (MUST) — In-app notifications via Pusher private-user.{id}; email digest for supervisors.

12. Reports

12.1 Principle

- Common reports service against read-replica.
- Filters: date range (Asia/Dhaka), channel (utm_source), courier, city, status.
- Every report exports CSV + XLSX; scheduled email delivery.
- Optional /api/v1/admin/reports/* endpoints for BI tools (Metabase/Looker).

12.2 Reports to Implement

Report	Contents
Sales Overview	GMV, Orders, AOV, CR; compare-to-prev.
Sales by Product / Variant / Category / Brand	Units, revenue, returns, net revenue, contribution margin.
Sales by Channel	Organic, paid social, direct, referral, email, SMS, landing pages.
Sales by Geo	City / Division / District with map.
New vs Returning	Mix, AOV differential, cohort retention.
Profit (P&L)	Revenue – COGS – shipping paid – payment fees – RTO losses – allocated ad spend → net margin; per order-item, aggregable.
ROAS / CAC / LTV	Per campaign, per SKU, per cohort.
Inventory	On-hand, stock movements, aging, reorder point, ABC analysis.
Courier Performance	Delivery rate, TAT, RTO rate per courier per zone.
Call Center KPIs	Calls handled, confirmation rate, AHT, callback adherence, RTO attributable per agent.
Fraud	Score distribution, blacklist hits, score-to-RTO correlation.
CAPI Match Rate	Client-only / server-only / deduplicated; top failing events.
Abandoned Cart	Funnel + recovered revenue.
Flash Sale	Sell-through %, TTS, conversion uplift vs baseline.

12.3 Profit Computation (per order-item)

- $\text{Revenue_net} = \text{unit_price} \times \text{qty} - \text{item_discount} - \text{apportioned_order_discount}$

- $\text{COGS} = \text{variant.cost_price} \times \text{qty}$ (moving average at order time)
- $\text{Shipping_charged} = \text{Shipping_paid} + \text{Payment_fee}$
- $\text{Contribution_margin} = \text{Revenue_net} - \text{COGS} - \text{Shipping_paid} - \text{Payment_fee}$
- $\text{Net_profit} = \text{Contribution_margin} - \text{allocated_ad_cost}$ (by attribution)

13. Realtime (Pusher)

Channel	Type	Events
public.storefront.global	Public	flash-sale.updated, banner.changed
public.stock.{variant_id}	Public	stock.changed, stock.sold-out, stock.restocked
public.flash-sale.{id}	Public	tick, sold-count, sold-out
private-order.{order_id}	Private	order.status.changed, order.tracking.updated
private-user.{user_id}	Private	notification.created, assignment.changed
private-order-board.admin	Private	order.created, order.status.changed, order.fraud.flagged
private-inventory.admin	Private	stock.low, stock.out, po.received
presence-agents.call-center	Presence	presence join/leave + capacity
private-dispatch.admin	Private	dispatch.failed, dispatch.succeeded, courier.webhook

- Envelope: { event, timestamp, actor, data }.
- Authorization: /api/broadcasting/auth enforces Policies against encoded resource ids.
- Throttle: stock.changed coalesces to max 1 event / 1 s per variant.
- Fallback polling: /api/stock/{id} every 30 s (storefront); /api/orders?since=... every 10 s (admin).
- Target: publish → UI render ≤ 500 ms P95, ≤ 1.5 s P99.

14. Tracking (GTM + Pixel + CAPI + GA4 + TikTok)

14.1 Pipes

- Client pipe — GTM Web Container fires Meta Pixel, GA4, TikTok Pixel. Carries event_id + fbp + fbc.
- Server pipe (primary) — Laravel Listeners post same events (same event_id) to Meta CAPI + GA4 Measurement Protocol + TikTok Events API.
- Server pipe (future) — sGTM on sgtm.klixbd.com for first-party tagging.
- Dedup: UUIDv4 event_id generated client-side (or checkout_session scoped); Meta dedupes event_name + event_id within 7 days.

14.2 Events

Event	Pipes	Trigger	Required Params
PageView	Client + Server	Every page	event_id, url, referrer, user_data (hashed), fbp, fbc
ViewContent	Client + Server	PDP, category view	content_ids, content_type, value, currency (BDT)
Search	Client	Search executed	search_string, result_count
AddToCart	Client + Server	Add to cart	content_ids, value, contents[]
InitiateCheckout	Client + Server	Checkout opened	content_ids, num_items, value, event_id = session id
AddPaymentInfo	Client + Server	Payment method selected	value, currency, content_ids
Lead	Client + Server	Phone captured (abandoned)	value (est), currency, user_data
Purchase	Client + Server	Order created (COD) OR payment confirmed (MFS/Card)	content_ids, contents, value, num_items, order_id, event_id
Purchase-Delivered (custom)	Server	Order → Delivered	order_id, value, event_id
Subscribe	Client + Server	Newsletter/SMS opt-in	user_data
CompleteRegistration	Client + Server	Signup	method, user_data
ReviewSubmitted (custom)	Server	Review created	rating, order_id

14.3 Requirements

- REQ-TRK-001 (MUST) — user_data includes SHA-256 hashed: email, phone (E.164 no +), first_name, last_name, city, country (BD). Target Event Match Quality ≥ 7.5.
- REQ-TRK-002 (MUST) — Persist fbp, fbc on checkout_session; attach to all related server events.
- REQ-TRK-003 (MUST) — external_id — stable hashed customer_id for cross-device attribution.
- REQ-TRK-004 (MUST) — Admin Integrations screen holds: GTM Web ID, sGTM URL, GA4 ID + API secret, Meta Pixel ID + CAPI token, TikTok Pixel ID + TikTok Events token.
- REQ-TRK-005 (MUST) — dataLayer uses GA4 enhanced ecommerce shape (view_item, add_to_cart, begin_checkout, purchase).

- REQ-TRK-006 (MUST) — Server pipeline: EnqueueAnalyticsEvent listener → capi queue (Horizon) → fanout jobs SendToMetaCapi / SendToGA4 / SendToTikTokEvents. Retries 3× (2s/10s/60s). Log payload + response to capi_event_log.
- REQ-TRK-007 (MUST) — Cookie banner (Necessary / Preferences / Analytics / Marketing); consent persisted; drop PII from server events when "Marketing: declined".
- REQ-TRK-008 (MUST) — Consent Mode v2 for GA4.

15. Third-Party Integrations

Integration	Direction	Priority	Purpose
Meta CAPI	Out	MUST v1.0	Server-side Pixel deduplicated events.
Meta Marketing API	In	SHOULD v1.1	Nightly ad-spend pull for ROAS.
GTM (web + server)	Out	MUST v1.0	Client + sGTM container.
GA4 Measurement Protocol	Out	MUST v1.0	Server-side GA4 events.
TikTok Events API	Out	SHOULD v1.1	TikTok ads attribution.
bKash (Tokenized)	Bi	MUST v1.0	Direct merchant.
Nagad PGW	Bi	MUST v1.0	Direct merchant.
SSLCOMMERZ	Bi	MUST v1.0	Cards + MFS + net banking aggregator.
AamarPay	Bi	SHOULD v1.1	Aggregator redundancy.
Pathao / Steadfast / RedX	Bi	MUST v1.0	Courier: parcel + webhook.
Sundarban	Bi	SHOULD v1.1	Outside-Dhaka + rural.
FraudBD / FraudChecker	Out	MUST v1.0	Phone fraud score.
SSL Wireless SMS (+ Alpha SMS failover)	Out	MUST v1.0	OTP, transactional, abandoned cart.
SES / SendGrid	Out	MUST v1.0	Transactional + marketing email.
Meta Messenger API	Out	SHOULD v1.1	Abandoned-cart recovery (24h window).
WhatsApp Cloud API	Out	NICE v2	Post-launch.
Barikoi / Mapbox	Out	SHOULD	Address pin for Dhaka.

Integration	Direction	Priority	Purpose
		v1.1	
Sentry + CloudWatch	Out	MUST v1.0	Errors, logs, metrics.
Pusher Channels	Out	MUST v1.0	Realtime.
Accounting export (Tally / QuickBooks CSV)	Out	SHOULD v1.1	Month-end journal.

- Credentials: integrations table with encrypted JSON (Laravel cast + app key); NOT in .env.
- Per-env credentials; staging uses sandbox.
- Admin "Test Connection" per integration (non-destructive).
- Health-check cron every 5 min; outages raise Ops Pusher alert.
- All webhook endpoints verify signature (HMAC / API key / shared secret) + IP allowlist where supported; idempotent by event_id.

16. Data Model

16.1 Principles

- bigint UNSIGNED PKs + uuid for external URLs.
- Money: integer minor units, column suffix _paisa.
- Timestamps on all tables; soft-delete only on content (products, blog); never on orders/financial.
- JSON for flexible attributes; *_translations tables for locale content.
- Indexes on every FK + status columns; (customer_id, created_at), (variant_id, created_at).
- utf8mb4 / utf8mb4_0900_ai_ci.
- FKs enforced; RESTRICT for business entities, CASCADE for child rows.

16.2 Core Tables

Table	Key Columns
users	id, uuid, name, email, phone_e164, password, role_id, twofa_secret, status, last_login_at
roles / permissions	Spatie permission tables
customers	id, uuid, name, email, phone_e164, default_address_id, marketing_sms, marketing_email, loyalty_points, ltv_paisa, risk_flag
addresses	id, customer_id, name, phone, division, district, thana, area, street, landmark, lat, lng, is_default_*
categories / brands / tags	Taxonomy (slug, name, image, SEO, sort).
products	id, uuid, slug, name, brand_id, category_id, status, has_variants,

Table	Key Columns
	base_price_paisa, compare_price_paisa, cost_price_paisa, weight_g, dims, tax_class_id, shipping_class_id, handling_days, published_at, custom_fields JSON
product_translations	product_id, locale, name, short_desc, description
product_images	id, product_id, media_id, sort, is_primary
options / option_values	Size/Color with optional swatch_hex.
variants	id, uuid, product_id, sku, barcode, price_paisa, cost_price_paisa, weight_g, stock_qty, backorder, image_id, status
variant_option_values	variant_id, option_value_id (junction)
media	id, disk, path, mime, size_kb, width, height, alt, title
warehouses / stock_movements	movements: variant_id, qty_delta, reason, reference_type, reference_id, unit_cost_paisa
purchase_orders / po_items	code, supplier_id, status, expected_at, totals, items (variant, qty, cost).
tax_classes / tax_rates	Rate + inclusive/exclusive flag.
shipping_zones / shipping_rates / shipping_classes	Zone rules (JSON) + named classes.
carts / cart_items	cart_token, customer_id (nullable), items.
checkout_sessions	uuid, cart_id, customer_id, status, payment_method, pricing_snapshot JSON, shipping_address JSON, contact_phone, contact_email, fraud_score, fbp, fbc, utm JSON, idempotency_key, expires_at
otp_codes	phone_e164, code_hash, attempts, expires_at, purpose, verified_at
orders	id, uuid, code, customer_id, checkout_session_id, status, payment_status, subtotal, discount_total, shipping_total, tax_total, grand_total (all_paisa), payment_method, courier, consignment_id, tracking_url, notes, risk_band, attribution JSON, ip, ua, source
order_items	id, order_id, variant_id, product_name, variant_name, sku, qty, unit_price_paisa, unit_cost_paisa, line_discount_paisa, line_total_paisa, tax_paisa
order_timeline	id, order_id, actor, event, from_status, to_status, note
order_payments / order_refunds	method, provider_ref, amount, fee, status, payload.
coupons /	Code + conditions/limits JSON; redemptions tie to order + customer.

Table	Key Columns
coupon_redemptions	
flash_sales / flash_sale_items	Sale window + per-item override.
loyalty_ledger / referrals	Points ledger + referral pairs.
reviews	product_id, variant_id, customer_id, order_id, rating, title, body, status, moderated_by
abandoned_carts	checkout_session_id, phone, email, last_step, attempts, recovered_order_id
landing_pages / experiments	Sections JSON, pixel override, A/B allocations.
call_tasks / call_dispositions	Per-order task + attempts with code + duration + recording_url.
integrations	key, config JSON (encrypted), enabled, tested_at
capi_event_log	event_name, event_id, payload JSON, provider, status_code, response JSON
audit_logs	user_id, event, auditable_type, auditable_id, old/new JSON, ip, ua
notifications / jobs / failed_jobs / job_batches / settings	Laravel standard + settings key/value JSON.
webhook_deliveries	integration, event_id, payload, status, attempts, response

17. API Endpoints

17.1 Conventions

- Base: /api/v1. JSON only. Envelopes: { data, meta, errors }.
- Auth: session cookie (storefront) + Sanctum (admin / native).
- Idempotency-Key header on POSTs that create orders/payments.
- Cursor pagination on high-volume lists; rate limits per-route (login 5/min, OTP 3/min).
- Errors: problem+json with code, message, fields[].

17.2 Storefront

M	Endpoint	Purpose
GET	/api/v1/catalog/categories	Category tree.
GET	/api/v1/catalog/products?...	PLP with filters/sort/page.

M	Endpoint	Purpose
GET	/api/v1/catalog/products/{slug}	PDP.
GET	/api/v1/catalog/search?q=	Search results.
GET	/api/v1/catalog/recommendations?product_id=	Related / cross-sell.
GET	/api/v1/stock/{variant_id}	Stock poll fallback.
POST	/api/v1/cart	Create/fetch cart.
POST/ PATCH/ DELETE	/api/v1/cart/items/{id}	Cart CRUD.
POST	/api/v1/cart/coupon	Apply coupon.
POST	/api/v1/checkout	Create checkout_session.
PATCH	/api/v1/checkout/{id}	Update session (address, payment, coupon).
POST	/api/v1/checkout/{id}/otp/[verify]	Request / verify OTP.
POST	/api/v1/checkout/{id}/place-order	Place order; returns order + payment redirect if any.
GET	/api/v1/orders/{code}/track	Public track by code + phone.
POST	/api/v1/auth/register login password/forgot logout	Auth flows.
GET	/api/v1/me[/orders wishlist]	Customer profile + history + wishlist.
POST	/api/v1/me/returns	Initiate return.
POST	/api/v1/reviews	Submit review (auth + purchased check).
POST	/api/v1/track/event	First-party event endpoint for sGTM hop.

17.3 Admin (RBAC)

M	Endpoint	Purpose
GET	/api/v1/admin/dashboard	KPI tiles (live).
GET	/api/v1/admin/orders/{id}	List / detail.
PATCH	/api/v1/admin/orders/{id}/status	State transition (policy-checked).
POST	/api/v1/admin/orders/bulk-dispatch	Bulk courier booking.
POST	/api/v1/admin/orders/{id}/refunds	Refund.

M	Endpoint	Purpose
CRUD	/api/v1/admin/products/{id}/variants]	Catalog CRUD + variants.
POST	/api/v1/admin/products/import	CSV import (async).
POST	/api/v1/admin/stock/adjust	Manual adjust.
CRUD	/api/v1/admin/purchase-orders/{id}/receive]	PO + receive.
GET	/api/v1/admin/customers	List + segments.
CRUD	/api/v1/admin/coupons /flash-sales /landing-pages	Marketing.
POST	/api/v1/admin/call-center/tasks/{id}/disposition	Agent disposition.
GET	/api/v1/admin/reports/{name}	Reports (sales / profit / inventory / capi-health / ...).
POST	/api/v1/admin/integrations/{key}/test	Test connection.
PATCH	/api/v1/admin/settings	Update settings group.
GET	/api/v1/admin/audit-logs	Audit trail.

17.4 Webhooks (inbound)

Provider	Endpoint	Security
bKash	/api/webhooks/payments/bkash	Signature + shared secret + IP allowlist.
Nagad	/api/webhooks/payments/nagad	Signature + IP allowlist.
SSLCOMMERZ	/api/webhooks/payments/sslcommerz	Server-to-server verify on receipt.
Pathao / RedX	/api/webhooks/couriers/{courier}	HMAC.
Steadfast	/api/webhooks/couriers/steadfast	API-key + IP allowlist.
SMS DLR	/api/webhooks/sms/{vendor}	Signed query token.
Meta Messenger	/api/webhooks/messenger	Verify + sha1 signature.

18. Non-Functional Requirements

ID	Category	Target	Requirement
NFR-PERF-001	Latency	P95 ≤ 400ms	API for PDP/PLP/Cart/Checkout GETs.

ID	Category	Target	Requirement
NFR-PERF-002	Latency	P95 $\leq$ 800ms	Place-order including fraud API (external budget 1.5s with circuit breaker).
NFR-PERF-003	FE	LCP $\leq$ 2.5s / INP $\leq$ 200ms	Storefront mobile P75.
NFR-PERF-004	Throughput	500 rps	Storefront reads, <1% errors.
NFR-PERF-005	Throughput	100 rps	Place-order, <1% errors.
NFR-PERF-006	Realtime	$\leq$ 500ms P95	Pusher publish $\rightarrow$ UI render.
NFR-SCAL-001	Scale	10 $\times$ horizontal	Stateless app tier; Redis sessions; autoscale queues per Horizon tag.
NFR-AVAL-001	Uptime	$\geq$ 99.5%	Monthly excl. scheduled maintenance $\leq$ 4h off-peak.
NFR-AVAL-002	DR	RTO 4h / RPO 30m	RDS Multi-AZ + snapshots + S3 replication.
NFR-AVAL-003	Resilience	All integrations	Circuit breakers — vendor outage cannot fail order creation.
NFR-REL-001	Retries	3 $\times$ exponential	External calls via Http pool + Guzzle middleware.
NFR-REL-002	Idempotency	All mutating externals	payments, courier booking, CAPI.
NFR-REL-003	DLQ	With replay UI	Failed jobs $\rightarrow$ dead-letter table + Ops alert.
NFR-OBS-001	Tracing	Request-Id end-to-end	X-Request-Id propagated to logs + outbound calls.
NFR-OBS-002	Logs	Structured JSON	Severity, context, request_id, user_id.
NFR-OBS-003	Metrics	Custom CloudWatch	orders/min, checkout success %, capi-match %.
NFR-OBS-004	Alerts	Defined thresholds	Orders drop > 50% for 10m; checkout err > 2% for 5m; capi-match < 60% for 30m; queue backlog > 5k.
NFR-MNT-001	Code	PSR-12 + PHPStan L6 + Pint	CI blocks on violation.
NFR-MNT-002	FE	TS strict + ESLint + Prettier	Shared component library.

ID	Category	Target	Requirement
NFR-MNT-003	Tests	≥ 70% / ≥ 80% services	Overall + domain services.
NFR-MNT-004	Flags	Laravel Pennant	Progressive rollout.
NFR-UX-001	A11y	WCAG 2.1 AA	Key flows (PDP, cart, checkout, account).
NFR-I18N-001	Locale	en + bn	Laravel translations + i18next; Asia/Dhaka UI; libphonenumber parse.

18.1 Data Retention

Data	Retention	Notes
Orders / timeline / invoices	Indefinite	Legal + tax.
capi_event_log	180 days	Truncate job.
otp_codes	30 days	Auto-purge.
audit_logs	5 years	Compliance.
Server logs	90 days	CloudWatch policy.
Abandoned carts (no PII)	1 year	Anonymize after recovery window.
Backups	30d rolling + 12 monthly	RDS automated + snapshots.

19. Security

- REQ-SEC-001 (MUST) — OWASP ASVS L2 assessed before launch.
- REQ-SEC-002 (MUST) — Inputs validated via Form Requests; output escaped by default.
- REQ-SEC-003 (MUST) — CSP restricts scripts to self + approved vendors (GTM, Pusher, CDN).
- REQ-SEC-004 (MUST) — Passwords bcrypt cost ≥ 12; TOTP secrets encrypted.
- REQ-SEC-005 (MUST) — Admin 2FA mandatory; cookies HttpOnly + Secure + SameSite=Lax; idle 8h / absolute 24h.
- REQ-SEC-006 (MUST) — Webhook signatures verified; unsigned rejected.
- REQ-SEC-007 (MUST) — Secrets in AWS Parameter Store (runtime); never in .env on disk.
- REQ-SEC-008 (MUST) — Data export + delete endpoints behind verified account.
- REQ-SEC-009 (MUST) — Card PAN never touches klixbd servers (PCI SAQ A only — hosted redirect).
- REQ-SEC-010 (MUST) — Rate-limit OTP, login, coupon apply, checkout submit.
- REQ-SEC-011 (MUST) — Audit log on sensitive models (products, prices, coupons, orders, users).

- REQ-SEC-012 (SHOULD) — Pentest pre-launch + annually; dep audits (composer/npm) in CI.
- REQ-SEC-013 (SHOULD) — SAST (PHPStan/Psalm + ESLint security) in CI; DAST (ZAP) on staging pre-release.

20. DevOps & Testing

20.1 CI/CD

- Mono-repo (backend, storefront, admin, infra, docs).
- Trunk-based; PR gated on lint + static analysis + tests.
- Artifacts: Docker image (backend) + static bundles (FE).
- Staging: auto-deploy on main + smoke tests.
- Prod: manual-gated (CTO/Tech Lead) + blue/green or rolling + graceful Horizon restart.
- Post-deploy: health check + Sentry release + rollback runbook linked.

20.2 Infra

- IaC: Terraform (VPC, ALB, ECS, RDS, ElastiCache, S3, CloudFront, Route53, SES, Secrets).
- Per-env Terraform state in S3 + DynamoDB lock.
- Env parity via module vars.
- DR drill twice a year.

20.3 Test Pyramid

Layer	Coverage	Examples
Unit	≥ 70% / ≥ 80% services	Pricing, fraud rules, courier rate calc, coupon validator, CAPI payload builder.
Feature (Laravel)	Every controller + policy	place-order: COD, fraud, partial-advance, duplicate idempotency.
Integration	Per external	Mocked SSLCOMMERZ/bKash/Pathao/CAPI with recorded cassettes.
FE	Components + hooks	Variant picker, checkout form validation, order-tracker realtime.
E2E (Playwright)	Happy + top-3 failures	Browse → PDP → Add → Checkout → COD; flash sale; admin dispatch.
Perf (k6)	Key endpoints	PDP 500 rps; place-order 100 rps; search 200 rps.
Security	Pre-release	ZAP on staging; admin authz matrix; OWASP top-10.

20.4 Test Data

- Factories + seeders for deterministic fixtures.

- Staging DB = prod clone with PII scrubbed (phones random, names faker, amounts preserved).
- Synthetic prod orders flagged `is_synthetic=true`; excluded from reports.

20.5 Observability

- Sentry (errors, releases by git SHA, source maps).
- CloudWatch Logs + Metrics + alarms.
- Telescope on staging.
- UptimeRobot heartbeats on `/healthz` (DB + Redis + queue depth).